

VERIQO External Qualification Track (P2)

Nothing in this document is claimed as done. It is the precise statement of what external qualification requires, what has been built toward it, and what has not happened — so that the distinction between *ready to be qualified* and *qualified* is never blurred in a proposal, a data room, or a customer conversation.

1. The distinction this document exists to protect

READY_FOR_REAL_QUALIFICATION is not QUALIFIED.

The first means: the engineering harness a real qualification would run through is built, and it passes. The second means: an external party with independent standing — a penetration testing firm, a cloud KMS, a real multi-region deployment, an auditor — actually performed the qualification and issued a result.

VERIQO has the first. It does not have the second, for any item on this list.

This is enforced structurally, not by editorial discipline: `docs/governance/CANONICAL_READINESS_TAXONOMY.md` describes a two-value verdict type whose only positive value is `TEMPORARY_PRODUCTION_READINESS_CANDIDATE`. **The type has no `PRODUCTION_QUALIFIED` constant.** It is not possible to construct a value expressing full qualification, so no generated report can claim one.

Language rule: any material describing VERIQO must never render `READY_FOR_REAL_QUALIFICATION` as "qualified", "certified", "validated", or "production-ready". Doing so in a proposal would be a material misrepresentation.

2. Current state of the eight tracked blockers

From `evidence/blockers-qualification-report.json`, freshly read: **all eight read `READY_FOR_REAL_QUALIFICATION`. None reads `QUALIFIED`, because no such value exists.**

Blocker	Harness built and passing	What is actually missing
<code>hsm_kms</code>	Key lifecycle, Ed25519 signing, revocation semantics, and an AWS KMS adapter <i>shape</i> .	A procured HSM or cloud KMS tenancy. This environment's placeholder AWS credentials were re-tried against a real <code>DescribeKey</code> call and AWS rejected them — confirming procurement-blocked, not engineering-blocked .
<code>pentest</code>	The system under test, and the harness for reproducing findings.	An independent penetration testing firm and an engagement. Cannot be internally simulated: the value of a pentest is that someone else did it.
<code>scale_qualification</code>	A 100-container, 1,000,000-envelope scale run with reconciliation and zero unauthorized records.	100 real physical or cloud nodes.
<code>multi_region_dr</code>	A multi-container DR failover drill with acknowledged-write and failback-convergence measurement.	Real multi-region infrastructure with real network partitions and real latency.
<code>soak_72h</code>	A 60-minute soak, passing.	A real 72-hour run at production scale, on production infrastructure, with production traffic.

Blocker	Harness built and passing	What is actually missing
<code>spire_mtls</code>	A live SPIRE mTLS handshake in-sandbox.	Production identity infrastructure.
<code>supply_chain_scan</code>	Clean <code>staticcheck</code> / <code>gosec</code> passes and SBOM generation.	A live vulnerability-feed integration against a current database (<code>govulncheck</code> and equivalents), which needs network access this environment blocks.
<code>live_data</code>	Complete ingestion contracts with validation, state machines, and simulated connectors that structurally cannot emit live-mode data .	Commercial market-data contracts. See the Real-World Network Model.

3. The qualification sequence

Ordered by dependency, not by preference. Later items are wasted effort if earlier ones have not happened.

Stage 1 — Real infrastructure. Nothing else on this list can proceed against a single-host sandbox deployment.

1. **HSM / cloud KMS.** Procure a tenancy; wire the existing adapter shape to it; migrate signing from file/memory key providers. Closes the largest single gap between VERIQO's cryptography being *real* and being *production-custody grade*.
2. **Production deployment.** Real cloud infrastructure, real storage with encryption at rest, real TLS termination, real secret management.
3. **Production identity.** SPIRE/mTLS in a real deployment; OIDC for customer SSO.

Stage 2 — Scale and endurance. Requires Stage 1.

1. **Multi-region.** Real regions, real partitions, measured failover and failback.
2. **100-node scale qualification.** The existing harness against real nodes.
3. **72-hour soak** at production scale. The point is the duration: resource leaks, log growth, WAL segment accumulation, and clock drift only appear over time.

Stage 3 — Independent scrutiny. Requires Stages 1–2, because qualifying a sandbox tells an auditor nothing about production.

1. **Penetration test** by an independent firm, with a written report and a remediation cycle.
2. **Vulnerability feed** wired into CI against a live database.
3. **Independent security audit**, including the trust model and the cryptographic design — not only the deployment.

4. What qualification would actually test that internal harnesses cannot

Worth stating, because "we already have a harness for that" is the tempting and wrong response to each item:

- **A pentest** finds what the people who built the system did not think to look for. A self-run harness tests the threat model its authors already hold — by construction, it cannot find the gap in that model.
- **A 72-hour soak** finds accumulation: memory growth, disk growth from WAL segments, file handle leaks, unbounded caches. A 60-minute soak cannot, regardless of load.
- **Real multi-region** finds partition behaviour under real latency, asymmetric routes, and partial failures. Containers on one host share a clock and a kernel and lie about all of it.

- **A real HSM** finds latency, rate limits, availability failure modes, and key-ceremony operational reality. An in-memory key provider has none of these.
- **An independent audit** finds design errors that internal review has become blind to.

Each of these is a category of finding that internal work is structurally incapable of producing. That is why the distinction in §1 matters and is not pedantry.

5. What is genuinely reusable

The engineering work already done is not wasted — it is what makes each external engagement short rather than exploratory:

- Failure-injection matrices and measurement capture already exist for scale, DR, and soak; a real run reuses them directly.
- The key abstraction already separates key *lifecycle* from key *custody*, so moving to an HSM changes the provider, not the calling code.
- Ingestion contracts, validation, and state machines already exist for every named external source; a live provider plugs into them.
- SBOM and static analysis already run in the verification script.
- Zero external Go dependencies on the gateway and core paths materially shrinks what a supply-chain audit has to examine.

The honest summary: **the internally-closeable half of every item is closed. The external half of every item is open, and no amount of further internal work will close it.**

6. Sequencing against commercial readiness

Per the Readiness Tier Framework, none of this gates **PAID-PILOT READY** — a first paying customer's questions are about durability, tenant binding, retention, and verifiability, all of which are closed.

All of it gates **PRODUCTION QUALIFIED**.

Two items deserve earlier attention than their tier placement suggests:

- **HSM/KMS custody**, because file-backed keys are acceptable for a pilot's trust model and are not acceptable once real value depends on the signatures.
- **A lightweight external security review**, short of a full pentest, because many enterprise customers will not put real evidence into a system that has had no external eyes on it, regardless of how the vendor characterizes its readiness.